

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
“НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО”

ОТЧЕТ

Факультет программной инженерии и компьютерной техники, направление: веб-технологии

Тема задания: Meowle Network Lab

Обучающийся: Говалло В.И. Р4110

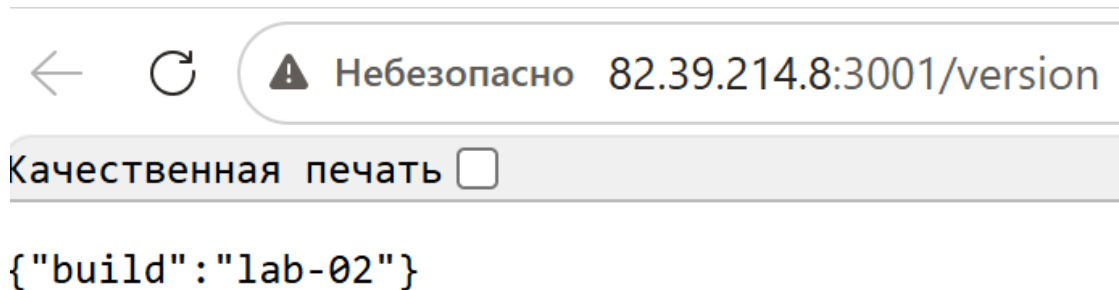
Санкт-Петербург

2026 г.

Исходные данные

Цель работы — анализ сетевого взаимодействия Android-приложения Meowle-lab.apk с учебным сервером Meowle. Приложение предварительно сконфигурировано для работы с тестовым backend API, поэтому все действия выполняются строго в пределах предоставленного стенда. Приложение запущено на андроид устройстве Xiaomi Redmi Note 14 Pro+ 5G. Перехват HTTP-трафика осуществляется с помощью Proxuman, а для ручной отправки запросов и проверки API задействованы браузер и утилита curl.

- Frontend: <http://144.31.255.0:8080>
- Backend API: <http://82.39.214.8:3001>
- Swagger UI: <http://82.39.214.8:3001/api-docs-ui/>
- Version check: <http://82.39.214.8:3001/version>



Установка приложения

Приложение установлено на Android-устройство, запущено, использованы входные данные:

- имя: `Алексей`
- телефон: `+79990000000`

ложениеВкладка рейтинг:

Настройка прокси

Прокси настроен по инструкции.

System Proxy:

✔ Overridden

IP=192.168.1.90 Port=9090

Toggle OFF

Ctrl+Shift+O

Port Number:

9090

✔ Auto Select Available Port

Automatically select new available port if it's occupied at launch.

Advanced:

☐ Only Listen on localhost

Listen on 127.0.0.1 (localhost) instead of 0.0.0.0

Restore Default

External Proxy Settings...

SOCKS Proxy Settings...

Трафик от приложения перехватывается

79	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	11:15:22.071	355ms	-	2.42 kB	
80	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	11:15:27.095	331ms	-	2.42 kB	
81	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	11:15:29.275	337ms	-	2.42 kB	
82	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	11:15:43.625	343ms	-	2.42 kB	
83	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	11:15:47.595	342ms	-	2.42 kB	

Выполнение работы:

Разведка API через Swagger

Swagger UI: <http://82.39.214.8:3001/api-docs-ui/>

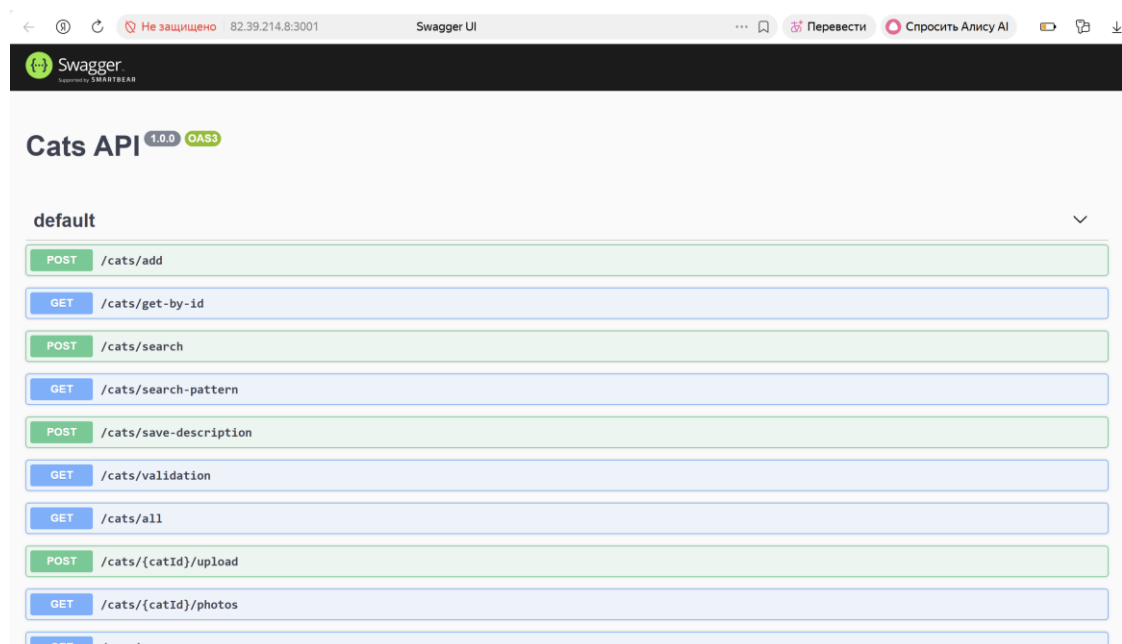


Таблица Арі-методов

Method	Path	Назначение	Параметры	Пример запроса	Пример ответа
POST	/cats/search	Поиск котиков	JSON: name, gender	<code>{"name":"Котик","gender":"male"}</code>	<code>{"groups":[{"title":"К","count":1,"cats":[{"id":1,"name":"Котик","description":"...", "gender":"male","likes":0,"dislikes":0}]}]}</code>
GET	/cats/get-by-id	Прочитать карточку по id	Query: id	<code>GET /cats/get-by-id?id=1</code>	<code>{"cat":{"id":1,"name":"Котик","description":"...", "gender":"male","likes":0,"dislikes":0}}</code>
POST	/cats/add	Добавление имени (котика)	JSON: cats [], (поля name, gender, desc	<code>{"cats":[{"name":"Барсик","gender":"male","description":"Пушистый"}]}</code>	<code>{"cats":[{"id":123,"name":"Барсик","description":"Пушистый","gender":"male","likes":0,"dislikes":0}]}</code>

			ription)		
POST	/cats/save-description	Изменить описание	JSON: catId, catDescription	{"catId":1,"catDescription":"Новое описание"}	{"id":1,"name":"Котик","description":"Новое описание","gender":"male","likes":0,"dislikes":0}
POST	/cats/{catId}/like	Лайк	Path: catId	POST /cats/1/like	OK
POST	/cats/{catId}/dislike	Дизлайк	Path: catId	POST /cats/1/dislike	OK
GET	/cats/likes-rating	Рейтинг по лайкам	Нет	GET /cats/likes-rating	[{"name":"Котик","likes":10}]
GET	/cats/dislikes-rating	Рейтинг по дизлайкам	Нет	GET /cats/dislikes-rating	[{"name":"Котик","dislikes":5}]

		ка м			
GET	/cats/ {catId }/photos	Пр ос мо т р ф о т о	Path : catId	GET /cats/1/photos	{"images":["/photos/photo1.jpg"]}
POST	/cats/ {catId }/upload	Заг руз ка ф о т о	Path : catId, mul tipa rt file	POST /cats/1/upload (файл)	{"fileUrl":"/photos/photo.jpg"}
DELETE	/cats/ {catId }/remove	Уд але ние дан ны х чер ез web API	Path : catId	DELETE /cats/1/remove	OK

Карта действий приложения

Выполнила в мобильном приложении:

1. Поиск котика.

2. Открытие карточки.
3. Лайк.
4. Дизлайк.
5. Добавление нового котика.
6. Изменение описания.
7. Загрузка изображения.
8. Открытие рейтинга.

1301	http://82.39.214.8:3001/api/core/cats/search	POST	200	12:03:30.102	357ms	45 B	144 B	-
1302	http://82.39.214.8:3001/api/core/cats/get-by-id?id=21	GET	200	12:03:33.894	383ms	-	105 B	-
1303	http://82.39.214.8:3001/api/photos/cats/21/photos	GET	200	12:03:33.895	396ms	-	13 B	-
1304	http://82.39.214.8:3001/api/likes/cats/21/likes	POST	200	12:03:37.390	323ms	29 B	97 B	-
1305	http://82.39.214.8:3001/api/likes/cats/21/likes	POST	200	12:03:41.089	343ms	29 B	97 B	-
1309	http://82.39.214.8:3001/api/core/cats/add	POST	200	12:04:14.832	429ms	111 B	152 B	-
1310	http://82.39.214.8:3001/api/core/cats/add	POST	200	12:04:15.717	331ms	111 B	89 B	-
1311	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	12:04:19.550	345ms	-	2.51 kB	-
1312	http://82.39.214.8:3001/api/core/cats/get-by-id?id=21	GET	200	12:04:22.059	413ms	-	105 B	-
1313	http://82.39.214.8:3001/api/photos/cats/21/photos	GET	200	12:04:22.069	398ms	-	13 B	-
1315	http://82.39.214.8:3001/api/core/cats/save-description	POST	200	12:04:34.716	340ms	68 B	127 B	-
1318	http://82.39.214.8:3001/api/photos/cats/21/upload	POST	200	12:05:19.600	804ms	70.9 kB	45 B	-
1319	http://82.39.214.8:3001/api/photos/cats/21/photos	GET	200	12:05:20.506	333ms	-	46 B	-
1320	http://82.39.214.8:3001/photos/image-1782551120398.jpg	GET	200	12:05:21.024	661ms	-	70.7 kB	-
1321	http://82.39.214.8:3001/photos/image-1782551120398.jpg	GET	200	12:05:21.036	662ms	-	70.7 kB	-
1323	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	12:05:27.035	326ms	-	2.57 kB	-
1324	http://82.39.214.8:3001/api/likes/cats/rating	GET	200	12:05:28.949	356ms	-	2.57 kB	-

Таблица карты действий

Де йст вие в пр ил ож ени и	Н Т Т Р m et h o d	URL	Request body	R es po ns e co de	Response body	Ко мм ент ари й
По иск кот ика	P O S T	http://82.39.214.8:3001/api/core/cats/search	{"gender":null,"name":"ppp","order":"asc"}	200	{"groups":[{"title":"P","cats":[{"id":21,"name":"Ppp","description":"ppp","tags":"","gender":"male","likes":0,"dislikes":0}], "count":1}]}	По иск по име ни "ppp"

						вер нул кот ика с id= 21
От кр ыт ие кар точ ки	G E T	http://82.39.214.8:3001/api/core/cats/get-by-id?id=21	-	20 0	{"cat":{"id":21,"name":"Ppp","description":"ppp","tags":"","gender":"male","likes":0,"dislikes":0}}	Кар точ ка кот ика с id= 21 пол уче на
Лайк	P O S T	http://82.39.214.8:3001/api/likes/cats/21/likes	{"dislike":false,"like":true}	20 0	{"id":21,"name":"Ppp","description":"ppp","tags":"","gender":"male","likes":1,"dislikes":0}	Лайк пос тавл ен
Дизлайк	P O S T	http://82.39.214.8:3001/api/likes/cats/21/likes	{"dislike":true,"like":false}	20 0	{"id":21,"name":"Ppp","description":"ppp","tags":"","gender":"male","likes":1,"dislikes":1}	Дизлайк пос тавл ен
Добавлен	P O	http://82.39.214.8:3001/ap	{"cats":[{"description":"милая	20 0	{"cats":[{"id":26,"name":"Маруся","description":"милая домашняя	Добавлен

ие нов ого кот ика	S T	i/core/cats/ad d	домашняя кошечка","g ender":"femal e","name":" Маруся"}}}		кошечка","tags":"","gender":"female ","likes":0,"dislikes":0}}}	кот ик с име нем "М ару ся", id= 26
Из ме нен ие оп иса ни я	P O S T	http://82.39.2 14.8:3001/ap i/core/cats/sa ve- description	{"catDescript ion":"милый игривый котик","catId ":21}	20 0	{"id":21,"name":"Ppp","description": "милый игривый котик","tags":"","gender":"male","li kes":1,"dislikes":1}	Оп иса ние кот ика с id= 21 обн овл ено на "ми лы й игр ив ый кот ик"

Загрузка изображения	POST	http://82.39.214.8:3001/api/photos/cats/21/upload	multipart/form-data; file="file.jpg"	200	{"fileUrl":"/photos/image-1782551120398.jpg"}	Файл загружен
Открытие рейтинга	GET	http://82.39.214.8:3001/api/likes/cats/rating	-	200	(полный JSON с двумя списками)	Рейтинг открыт

Изменение запросов

Выполнены 6 экспериментов с изменением запросов через прокси.

1. Изменение catId в карточке

Исходный запрос:

GET /api/core/cats/get-by-id?id=21

Измененный запрос и ответ сервера:

```
ubuntu@DESKTOP-CM0LTJ7:~/mnt/c/Users/Admin$ curl -i 'http://82.39.214.8:3001/api/core/cats/get-by-id?id=999999'
HTTP/1.1 404 Not Found
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 160
ETag: W/"a0-witMKWtCXXW5LrYUsOpP62u1fVQ"
Date: Sat, 27 Jun 2026 10:07:41 GMT
Connection: keep-alive
```

Состояние данных не изменилось, это не баг, просто неприятность.

2. Повтор лайка

Исходный запрос:

POST /api/likes/cats/21/likes

Тело: {"like":true,"dislike":false}

Измененный запрос и ответ сервера:

```

ubuntu@DESKTOP-CM0LTJ7:/mnt/c/Users/Admin$ curl -i -X POST 'http://82.39.214.8:3001/api/likes/cats/21/likes' \
-H 'Content-Type: application/json' \
-d '{"like":true,"dislike":false}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 127
ETag: W/"7f-LLG5r0J9FufT2kjWGYIpHEPIdas"
Date: Sat, 27 Jun 2026 10:12:38 GMT
Connection: keep-alive

{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":6,"dislikes":1}ubuntu
LTJ7:/mnt/c/Users/Admin$ curl -i -X POST 'hcurl -i -X POST 'http://82.39.214.8:3001/api/likes/cats/21/likes' \
-H 'Content-Type: application/json' \
-d '{"like":true,"dislike":false}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 127
ETag: W/"7f-b56PnXJWC9trn3IYBKMc9cSPqw"
Date: Sat, 27 Jun 2026 10:12:44 GMT
Connection: keep-alive

{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":7,"dislikes":1}ubuntu

```

Количество лайков увеличивается при каждом повторном запросе.

Вывод: Это security-проблема – возможность накрутки рейтинга. Сервер не проверяет, ставил ли уже этот пользователь лайк, и позволяет увеличивать счётчик повторными запросами. Рекомендуется сделать голосование идемпотентным: хранить факт голоса для каждого пользователя и не увеличивать счётчик повторно.

3. Изменение описания чужой записи

Исходный запрос:

POST /api/core/cats/save-description

Тело: {"catId":21,"catDescription":"милый игривый котик"}

Измененный запрос и ответ сервера:

```

ubuntu@DESKTOP-CM0LTJ7:/mnt/c/Users/Admin$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/save-description' \
-H 'Content-Type: application/json' \
-d '{"catId":5,"catDescription":"ВЗЛОМ"}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 104
ETag: W/"68-qjNIL4gyLGKP9awgKVFcBa24Vss"
Date: Sat, 27 Jun 2026 10:14:40 GMT
Connection: keep-alive

{"id":5,"name":"Буся","description":"ВЗЛОМ","tags":"","gender":"female","likes":4,"dislikes":3}ubuntu@DESKTOP-CM0LTJ7:/

```

Описание чужого кота изменилось.

Это критическая уязвимость. Сервер не проверяет права доступа при изменении описания, позволяя любому пользователю редактировать чужие объекты. Нужно добавить проверку пользователей и запретить редактировать чужие записи.

4. Дубликат имени

Исходный запрос:

POST /api/core/cats/add

Тело: {"cats":[{"name":"Маруся","gender":"female","description":"милая домашняя кошечка"}]}

Измененный запрос и ответ сервера:

```
ubuntu@DESKTOP-CM0LTJ7:~$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/add' \
  -H 'Content-Type: application/json' \
  -d '{"cats":[{"name":"Маруся","gender":"female","description":"дубликат"}]}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 89
ETag: W/"59-l7R+7pd5VdxnNGJXQmsqucogac"
Date: Sat, 27 Jun 2026 10:16:18 GMT
Connection: keep-alive

{"cats":[{"errorDescription":"Такое значение уже существует"}]}
```

Состояние данных не изменилось.

Сервер корректно отклоняет дубликат, но есть баг HTTP-статуса – не отличить успех от ошибки. Можно поставить 409 Conflict с описанием ошибки в теле ответа.

5. Неправильный пол

Исходный запрос (корректный):

POST /api/core/cats/add

Тело: {"cats":[{"name":"ПроверкаNeuter","gender":"female","description":"нормальный пол"}]}

Измененный запрос и ответ сервера:

```
nt/c/Users/Admicurl -i -X POST 'http://82.39.214.8:3001/api/core/cats/add' \
  -H 'Content-Type: application/json' \
  -d '{"cats":[{"name":"ПроверкаNeuter","gender":"neuter","description":"средний пол"}]}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 78
ETag: W/"4e-0RvNCplSE8bfuTf4cybItjwIE/A"
Date: Sat, 27 Jun 2026 10:20:08 GMT
Connection: keep-alive
```

Создан объект с исправленным полом.

Сервер должен отклонять такие значения. Это баг. Нужно возвращать 400 Bad Request.

6. Неправильное имя

Исходный запрос (корректный):

POST /api/core/cats/add

Тело: {"cats":[{"name":"Котя","gender":"female","description":"корректное имя"}]}

Измененный запрос и ответ сервера:

```
ubuntu@DESKTOP-CM0LTJ7:/mnt/c/Users/Admin$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/add' \
  -H 'Content-Type: application/json' \
  -d '{"cats":[{"name":"Кот123","gender":"female","description":"имя с цифрами"}]}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 73
ETag: W/"49-HoifCwS3JBQOyU83aY7zzEQc068"
Date: Sat, 27 Jun 2026 10:21:54 GMT
Connection: keep-alive

{"cats":[{"errorDescription":"Цифры не принимаются!"}]}ubuntu@DESKTOP-CM0LTJ7:/mnt/c/Users/Admin$ |
```

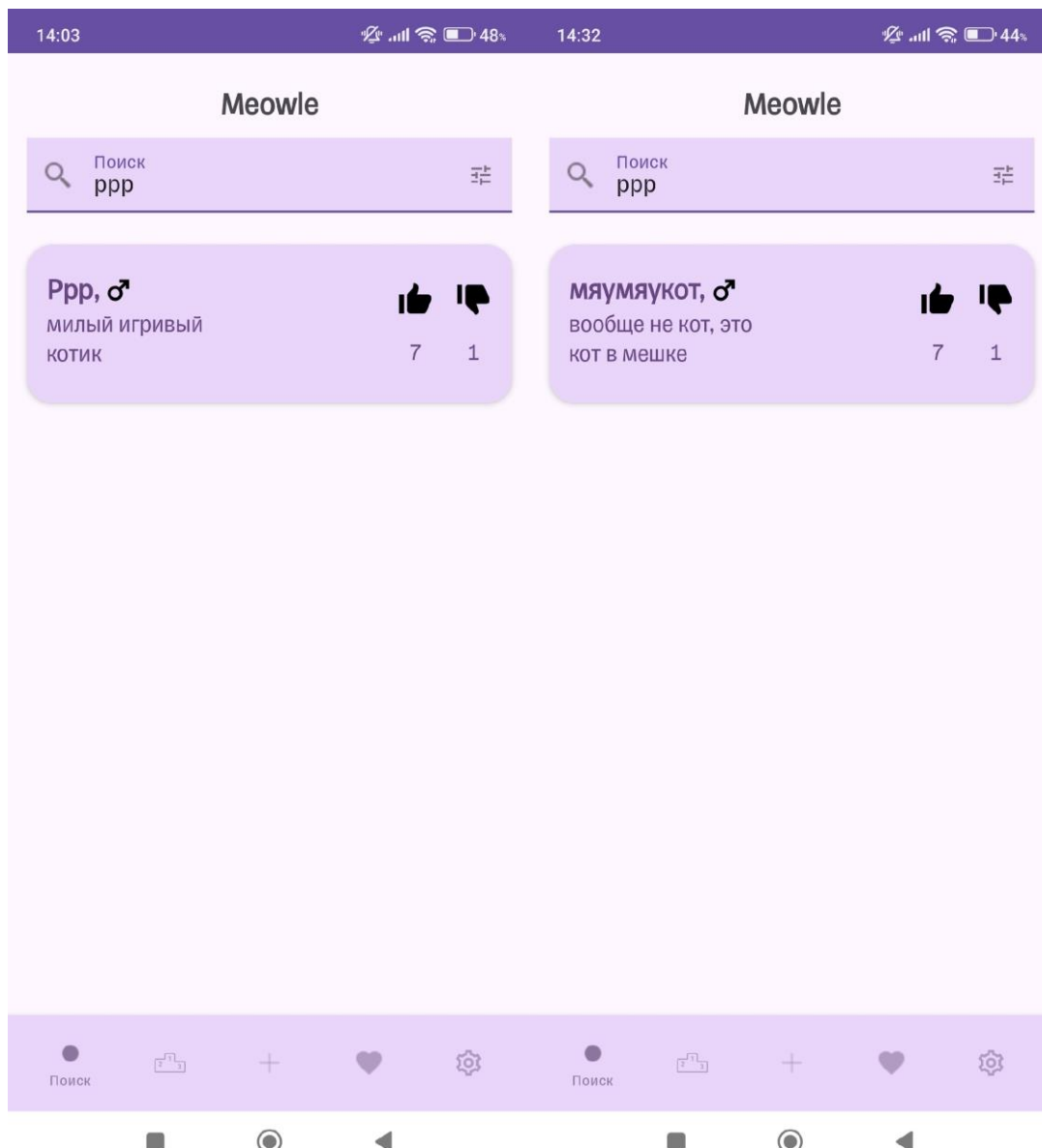
Нет, данные не изменились.

Валидация есть, но HTTP-статус – 200 (должен быть 400 Bad Request). Это баг статуса.

Изменение ответов

Эксперимент 1. Подмена имени и описания в ответе поиска.

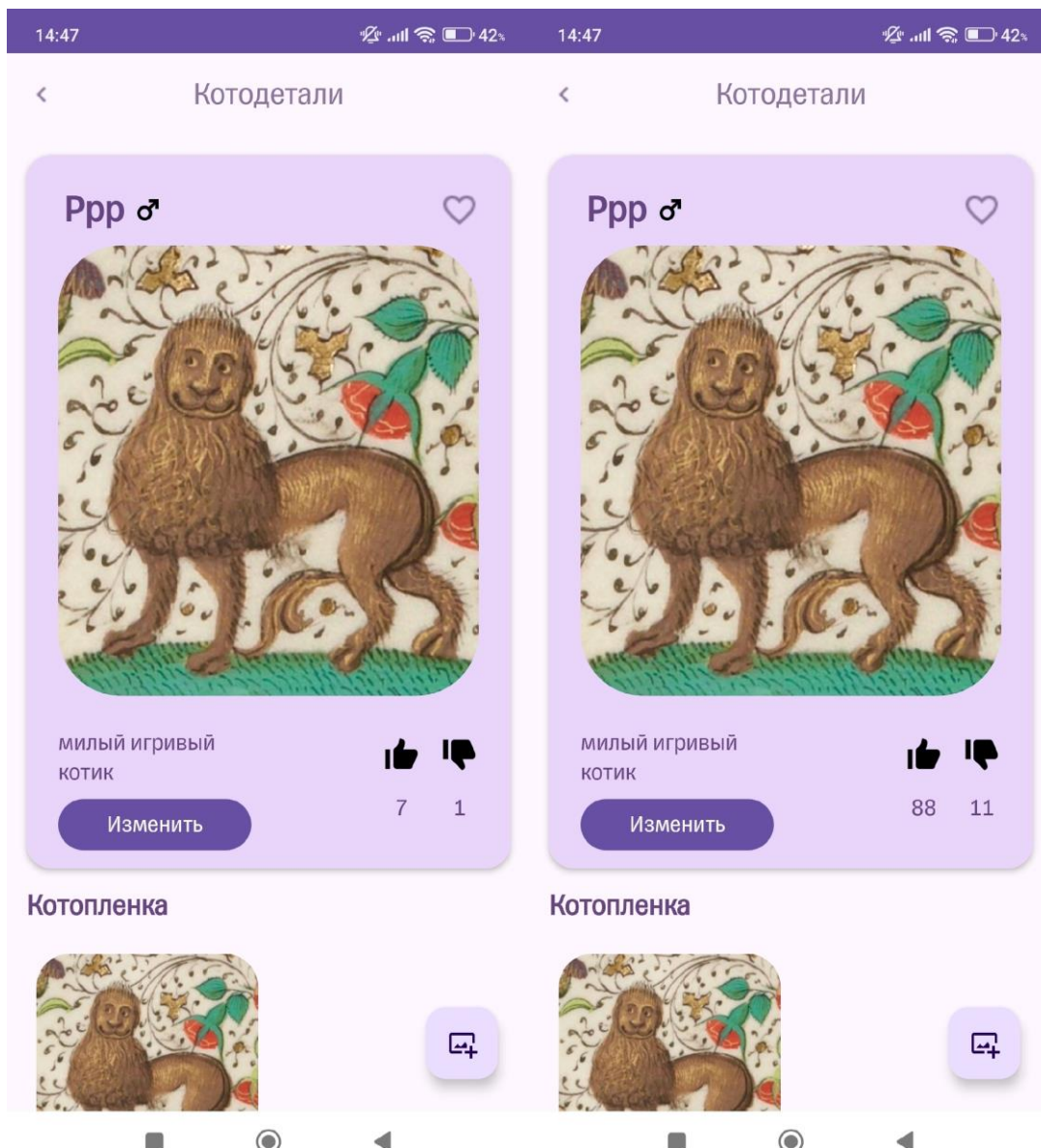
Подменяемый запрос: POST /api/core/cats/search



Приложение показало подставленные имя и описание, но после отключения подмены вернулись реальные данные. Это доказывает, что изменения коснулись только интерфейса – сервер хранит неизменную информацию. Клиент доверяет серверу без проверок, поэтому все важные проверки должны выполняться на серверной стороне.

Эксперимент 2: Подмена количества лайков/дизлайков.

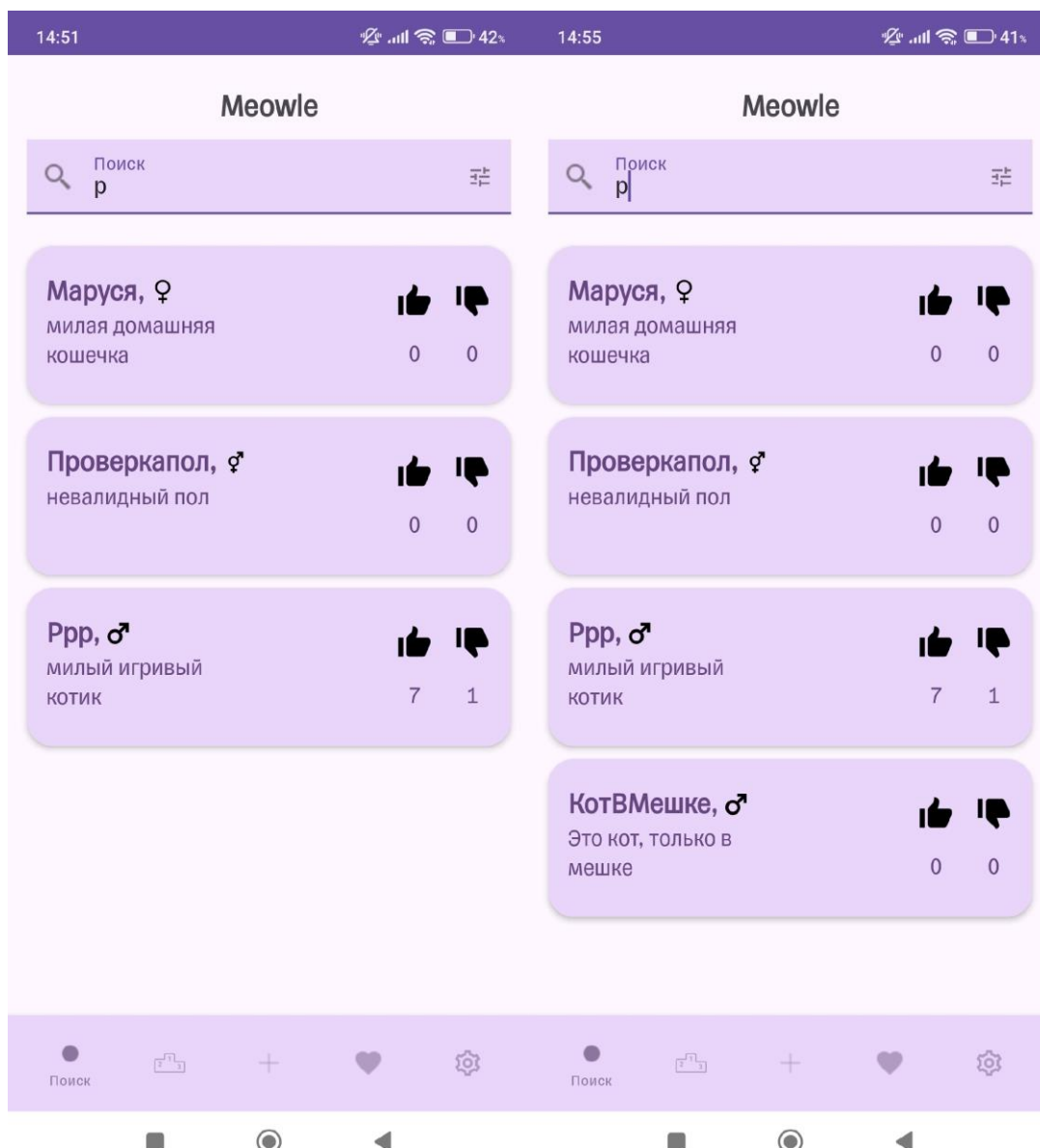
Подменяемый запрос: GET /api/core/cats/get-by-id?id=21



Приложение показало подставленные счётчики лайков и дизлайков, но после отключения подмены вернулись реальные значения. Это подтверждает, что изменения коснулись только интерфейса – сервер хранит неизменную информацию. Клиент доверяет серверу без проверок, поэтому все важные проверки должны выполняться на серверной стороне.

Эксперимент 3. Подмена списка результатов поиска

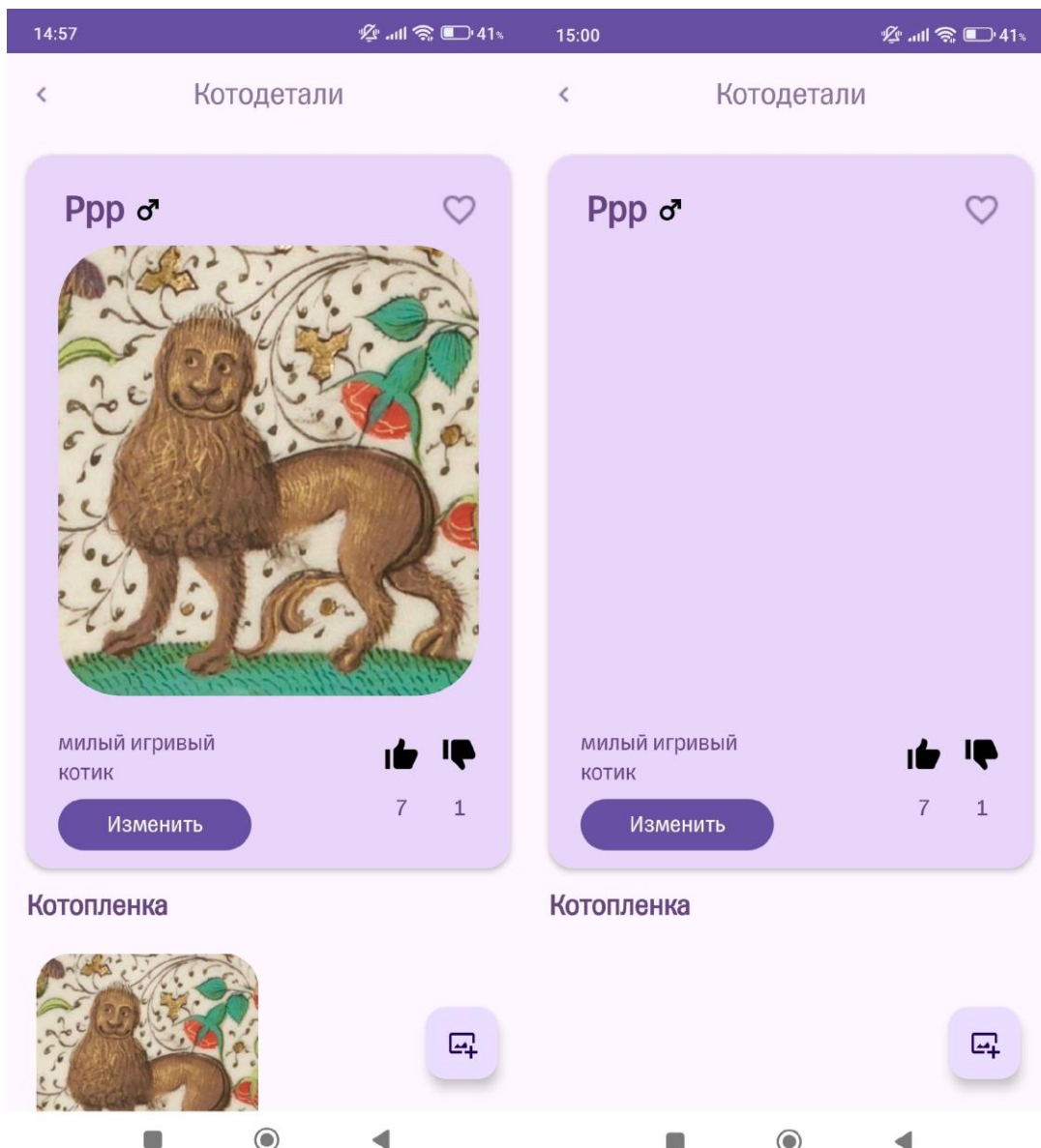
Подменяемый запрос: POST /api/core/cats/search



В результаты поиска добавлен несуществующий кот, который отобразился в приложении. После отключения подмены новый кот исчез, что подтверждает: изменения остались только на клиенте. Сервер не содержит этого объекта. Клиент доверяет списку, но проверка существования объекта выполняется на серверной стороне.

Эксперимент 4. Подмена списка фото или URL изображения

Подменяемый запрос: GET /api/photos/cats/21/photos



Приложение попыталось загрузить изображение по подменённому URL, но после отключения подмены вернулись реальные данные (или их отсутствие). Это подтверждает, что изменения остались только на клиенте. Сервер не создаёт новые файлы из подменённых URL. Клиент доверяет полученному списку, но загрузка и хранение файлов контролируются сервером.

SECURITY-АНАЛИЗ

Проблема 1. Отсутствие обязательной авторизации

Запросы к API выполняются без проверки подлинности пользователя.

High

Preconditions: доступ к сети и знание адреса API (<http://82.39.214.8:3001>).

Steps to reproduce: отправить любой запрос к API без заголовка авторизации (например,

GET /api/likes/cats/rating).

Actual result: сервер возвращает данные без проверки прав.

Expected result: сервер должен возвращать 401 Unauthorized для неавторизованных запросов.

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i 'http://82.39.214.8:3001/api/likes/cats/rating'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 2438
ETag: W/"986-RhBu9zoUzSyaRLUTK9Q4N0h9vIE"
Date: Sat, 27 Jun 2026 12:18:09 GMT
Connection: keep-alive

{"likes":[{"id":13,"name":"Котэ","description":"Алькотек не алькотек","tags":"","gender":"male","likes":8,"dislikes":2},{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":7,"dislikes":1},{"id":5,"name":"Буся","description":"БЗЛОМ","tags":"","gender":"female","likes":4,"dislikes":3},{"id":8,"name":"Бел","description":"","tags":"","gender":"male","likes":1,"dislikes":0},{"id":18,"name":"Кошка","description":"test OR '1'='1","tags":"","gender":"male","likes":1,"dislikes":0},{"id":4,"name":"Кекс","description":"Имя для экспериментов с поиском","tags":"","gender":"unisex","likes":0,"dislikes":0},{"id":12,"name":"Коте","description":"","tags":"","gender":"male","likes":0,"dislikes":0},{"id":11,"name":"Ллл","description":"","tags":"","gender":"male","likes":0,"dislikes":0},{"id":26,"name":"Маруся","description":"милая домашняя кошечка","tags":"","gender":"female","likes":0,"dislikes":0},{"id":30,"name":"Проверканол","description":"невалидный пол","tags":"","gender":"unisex","likes":0,"dislikes":0}]}{"id":5,"name":"Буся","description":"БЗЛОМ","tags":"","gender":"female","likes":4,"dislikes":3}{"id":13,"name":"Котэ","description":"Алькотек не алькотек","tags":"","gender":"male","likes":8,"dislikes":2}{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":7,"dislikes":1}{"id":8,"name":"Бел","description":"","tags":"","gender":"male","likes":1,"dislikes":0}{"id":4,"name":"Кекс","description":"","tags":"","gender":"unisex","likes":0,"dislikes":0}{"id":12,"name":"Коте","description":"","tags":"","gender":"male","likes":0,"dislikes":0}{"id":18,"name":"Кошка","description":"test OR '1'='1","tags":"","gender":"male","likes":1,"dislikes":0}{"id":11,"name":"Ллл","description":"","tags":"","gender":"male","likes":0,"dislikes":0}{"id":26,"name":"Маруся","description":"милая домашняя кошечка","tags":"","gender":"female","likes":0,"dislikes":0}{"id":30,"name":"Проверканол","description":"невалидный пол","tags":"","gender":"unisex","likes":0,"dislikes":0}]}
```

Recommendation: внедрить механизм аутентификации и проверять его на каждом запросе, изменяющем или читающем данные.

Проблема 2. IDOR – изменение описания чужой записи

Возможность изменить описание кота, созданного другим пользователем.

High

Preconditions: знать Id чужой записи .

Steps to reproduce: найти чужого кота, запомнить его id. Отправить POST /api/core/cats/save-description с catId чужого кота и новым описанием.

Actual result: описание изменяется, сервер возвращает 200 OK.

Expected result: сервер должен проверить права на редактирование и вернуть 403 Forbidden.

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/save-description' -H 'Content-Type: application/json' -d '{"catId":5,"catDescription":"БЗЛОМ"}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 104
ETag: W/"68-gjN1L4gyLGKP9awgKVCfBa24Vss"
Date: Sat, 27 Jun 2026 12:19:18 GMT
Connection: keep-alive

{"id":5,"name":"Буся","description":"БЗЛОМ","tags":"","gender":"female","likes":4,"dislikes":3}
```

Recommendation: добавить проверку владельца объекта на сервере; разрешать изменение только для объектов, созданных текущим пользователем.

Проблема 3. Повтор лайка (накрутка рейтинга)

Повторные запросы лайка увеличивают счётчик без ограничений.

Medium

Preconditions: знать catId и иметь доступ к endpoint-у лайка.

Steps to reproduce: отправить POST /api/likes/cats/21/likes с {"like":true,"dislike":false}.

Повторить тот же запрос несколько раз.

Actual result: счётчик likes увеличивается с каждым повтором.

Expected result: повторный лайк не должен увеличивать счётчик (идемпотентность) –

сервер должен запоминать, ставил ли пользователь лайк.

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/likes/cats/21/likes' -H 'Content-Type: application/json' -d '{"like":true,"dislike":false}'
# Повторите эту же команду ещё раз
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 127
ETag: W/"7f-HIo4ImFp11IPpiox90Sq7/Pp8PQ"
Date: Sat, 27 Jun 2026 12:20:12 GMT
Connection: keep-alive

{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":8,"dislikes":1}ubuntu@DESKTOP-CM0LTJ7:~/ios-course$
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/likes/cats/21/likes' -H 'Content-Type: application/json' -d '{"like":true,"dislike":false}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 127
ETag: W/"7f-MkuP8Ci/Kl0okgG400ea36PqSbY"
Date: Sat, 27 Jun 2026 12:20:25 GMT
Connection: keep-alive

{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":8,"dislikes":1}ubuntu@DESKTOP-CM0LTJ7:~/ios-course$
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/likes/cats/21/likes' -H 'Content-Type: application/json' -d '{"like":true,"dislike":false}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 128
ETag: W/"80-H37ASyDqirValpAhveq/87TlDs8"
Date: Sat, 27 Jun 2026 12:20:33 GMT
Connection: keep-alive

{"id":21,"name":"Ppp","description":"милый игривый котик","tags":"","gender":"male","likes":10,"dislikes":1}ubuntu@DESKTOP-CM0LTJ7:~/ios-course$
```

Recommendation: хранить только один голос пользователя для каждого кота и не учитывать повторные голоса.

Проблема 4. Тихая замена невалидного gender

Сервер принимает невалидное значение gender и молча заменяет его на unisex.

Medium

Preconditions: доступ к endpoint-у добавления кота.

Steps to reproduce: отправить POST /api/core/cats/add с "gender": "dragon".

Actual result: сервер создаёт запись с "gender": "unisex" (возвращает 200 OK).

Expected result: сервер должен отклонить запрос с 400 Bad Request и указать допустимые значения (male, female, unisex).

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/add' -H 'Content-Type: application/json' -d '{"cats":[{"name":"ПроверкаNeuter","gender":"neuter","description":"средний пол"}]}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 78
ETag: W/"4e-0RvNCplSE8bfuTf4cybItjwIE/A"
Date: Sat, 27 Jun 2026 12:22:47 GMT
Connection: keep-alive

{"cats":[{"errorDescription":"Только имена на русском!"}]}
```

Recommendation: добавить строгую валидацию полей на сервере и возвращать ошибку с описанием допустимых значений.

Проблема 5. Ошибки валидации возвращаются с HTTP 200 OK

Дубликат имени, невалидное имя возвращаются с кодом 200 вместо 4xx.

Low

Preconditions: возможность отправить некорректный запрос.

Steps to reproduce: отправить запрос на добавление кота с именем, которое уже существует либо с именем, содержащим цифры.

Actual result: сервер возвращает 200 OK и ошибку в теле ответа (например, {"errorDescription":"Цифры не принимаются!"}).

Expected result: для ошибок валидации сервер должен возвращать 400 Bad Request (или 409 Conflict для дубликатов).

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/api/core/cats/add' -H 'Content-type: application/json' -d '{"cats":[{"name": "Kor123", "gender": "female", "description": "имя с цифрами"}]}'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 73
ETag: W/"49-HoifCwS3JBQ0yU83aV7zzEQc068"
Date: Sat, 27 Jun 2026 12:23:46 GMT
Connection: keep-alive

{"cats":[{"errorDescription": "Цифры не принимаются!"}]}ubuntu@DESKTOP-CM0LTJ7:~/ios-course$
```

Recommendation: Использовать правильные HTTP-статусы для ошибок: 400, 409, 404.

Проблема 6. Web API-методы доступны напрямую

Методы без префикса доступны и могут изменять состояние, минуя мобильный сценарий.

Medium

Preconditions: Знание адресов web API (например, /cats/{catId}/like).

Steps to reproduce: отправить POST /cats/21/like напрямую.

Actual result: сервер принимает запрос и увеличивает лайк.

Expected result: доступ к web API должен быть ограничен или требовать дополнительной авторизации, если он не предназначен для публичного использования.

```
ubuntu@DESKTOP-CM0LTJ7:~/ios-course$ curl -i -X POST 'http://82.39.214.8:3001/cats/21/like'
HTTP/1.1 200 OK
X-Powered-By: Express
Content-Type: text/html; charset=utf-8
Content-Length: 2
ETag: W/"2-n009QiTIwXgNtWtBJezz8kv3SLc"
Date: Sat, 27 Jun 2026 12:25:34 GMT
Connection: keep-alive
```

Recommendation: если web API не нужно использоваться публично – закрыть их или добавить проверки.

Вывод

В ходе выполнения лабораторной работы был проведён анализ сетевого взаимодействия мобильного приложения Meowle с backend API, а также выполнена оценка безопасности API-методов.

Обнаруженные уязвимости (отсутствие авторизации, IDOR, возможность накрутки рейтинга, некорректные HTTP-статусы, слабая валидация и доступ к web API) показывают, что критичные проверки должны выполняться исключительно на сервере. Все операции, влияющие на данные, должны быть защищены аутентификацией, проверкой прав, идемпотентностью и строгой валидацией.

Таким образом, сервер является единственным надёжным звеном в системе, а клиент должен рассматриваться как потенциально небезопасный.

